

Cheat Sheet: CompTIA Security+

Estimated duration: **15** minutes

Welcome! This cheat sheet is here to help you with your technical preparations for the CompTIA Security+ certification exam. This cheat sheet focuses on the technical skills and resources necessary for exam preparations.

What you will learn

In this reading, you will:

- Review the CompTIA CySA exam domains, their core knowledge learning objectives, and the skills and tools.
- Review the tools required for various tasks.
- Identify effective exam study resources for comprehensive preparation.
- Gain tips to develop a structured study schedule and take tests to optimize learning.

Review the exam domains and their core knowledge, skills, and tools

The CompTIA Security+ exam covers essential security topics across five domains. Let's review the core knowledge objectives and the skills and tools associated with each domain.

1.0 General Security Concepts

The General Security Concepts domain covers the foundational security aspects necessary for understanding and managing a secure environment. Here's a breakdown of the key topics covered:

1.1 Compare and contrast various types of security controls

This section highlights the different categories and types of security controls, focusing on:

- **Categories:** Technical, Managerial, Operational, and Physical controls.
- **Control types:** Preventive, Deterrent, Detective, Corrective, Compensating, and Directive controls.

1.2 Summarize fundamental security concepts

This area addresses fundamental security principles and models, including:

- **Core security concepts:** Confidentiality, integrity, availability (CIA), and non-repudiation.
- **AAA model:** Authentication, Authorization, and Accounting, including authentication of people and systems and authorization models.
- **Zero-trust security:** This type of security uses a control plane, which can include adaptive identity and policy-driven access, and a data plane, including implicit trust zones and policy enforcement.
- **Physical security measures:** Fencing, video surveillance, access control, sensors, and more.
- **Deception technologies:** Honeypots, honeynets, and honeytokens for detecting threats.

1.3 Explain the importance of change management processes and their impact on security

This section covers how change management impacts security operations, emphasizing:

- **Business processes:** Strategize and document approval processes, stakeholder involvement, impact analysis, and backout plans.
- **Technical implications:** Including allow lists/deny lists, service restarts, downtime, and dealing with legacy applications.
- **Documentation and version control:** Ensuring updated diagrams, policies, and procedures are in place for proper security management.

1.4 Explain the importance of using appropriate cryptographic solutions

This area focuses on the appropriate use of cryptographic tools and solutions, covering:

- **Public Key Infrastructure (PKI):** Public/Private key management, certificate authorities, and revocation methods.
- **Encryption techniques:** Full-disk, file-level, database encryption, and key management strategies.
- **Cryptographic tools:** TPM, hardware security modules (HSM), and key management systems.
- **Obfuscation and hashing:** Methodssuch as steganography, tokenization, and data masking.
- **Certificates:** Understanding certificate authorities, revocation lists, and certificate signing.

2.0 Threats, Vulnerabilities, and Mitigations

The Threats, Vulnerabilities, and Mitigations domain focuses on identifying and understanding the different types of threats, vulnerabilities, and corresponding mitigation strategies to secure an enterprise. The core topics include:

2.1 Compare and contrast common threat actors and motivations

This section reviews the different types of threat actors, their attributes, and motivations, including:

- **Threat actors:** Nation-state, unskilled attackers, hacktivists, insider threats, organized crime, and shadow IT.
- **Actor attributes:** Internal versus external, resources and funding, level of sophistication and capability.
- **Motivations:** Data exfiltration, espionage, financial gain, blackmail, disruption, chaos, and philosophical or political beliefs.

2.2 Explain common threat vectors and attack surfaces

This topic explores the different vectors and surfaces where threats can exploit vulnerabilities, such as:

- **Message-based vectors:** Email, SMS, instant messaging.

- **Network-based vectors:** Wireless, wired, Bluetooth, and unsecured networks.
- **Human vectors:** Social engineering techniques such as phishing, vishing, pretexting, and brand impersonation.
- **Supply chain risks:** Vulnerabilities in managed service providers (MSPs), vendors, and suppliers.

2.3 Explain various types of vulnerabilities

This section focuses on the types of vulnerabilities that can exist in systems, including:

- **Application and OS-based vulnerabilities:** Memory injection, buffer overflow, race conditions, and SQL injection.
- **Hardware and cloud-based vulnerabilities:** End-of-life hardware, firmware issues, VM escape, and supply chain risks.
- **Misconfigurations and cryptographic weaknesses:** Issues such as zero-day vulnerabilities, mobile device risks, and cryptographic weaknesses.

2.4 Analyze indicators of malicious activity

This area involves identifying indicators that suggest malicious activity, such as:

- **Malware attacks:** Ransomware, viruses, Trojans, worms, and keyloggers.
- **Physical and network attacks:** Brute force, DDoS, RFID cloning, DNS attacks, and credential replay.
- **Application and cryptographic attacks:** Injection attacks, buffer overflows, privilege escalation, and cryptographic collisions.

2.5 Explain the purpose of mitigation techniques used to secure the enterprise

This section covers mitigation techniques used to reduce or prevent security risks, including:

- **Segmentation and access control:** Implementing access control lists (ACLs) and permissions.
- **Patching and hardening:** Applying updates using encryption and endpoint protection.
- **Monitoring and least privilege:** Continuous monitoring, enforcing least privilege, and removing unnecessary software.

3.0 Security Architecture

The Security Architecture domain focuses on the foundational elements necessary to protect enterprise infrastructure through a strategic approach to design and deployment. The core topics include:

3.1 Compare and contrast security implications of different architecture models

This section evaluates various architecture models and their security considerations, including:

- **Cloud architecture:** Understanding the responsibility matrix, hybrid considerations, and the impact of third-party vendors.
- **Infrastructure as Code (IaC), serverless, microservices:** Security implications in modern development practices.
- **Network infrastructure:** Concepts such as physical isolation (air-gapped), logical segmentation, and software-defined networking (SDN).
- **On-premises versus decentralized models:** Exploring the security challenges of centralized versus decentralized architecture, containerization, virtualization, and Internet of Things (IoT) devices.
- **Industrial Control Systems (ICS):** Security considerations for supervisory control and data acquisition (SCADA) systems and real-time operating systems (RTOS).
- **High availability considerations:** Evaluating aspects such as availability, resilience, cost, scalability, and ease of deployment.

3.2 Apply security principles to secure enterprise infrastructure

This section emphasizes applying security principles in various infrastructure scenarios, covering:

- **Infrastructure considerations:** Device placement, security zones, attack surfaces, connectivity, and failure modes (fail-open versus fail-closed).
- **Network appliances:** Utilizing jump servers, proxy servers, intrusion prevention/detection systems (IPS/IDS), and load balancers.
- **Secure communication:** Implementing Virtual Private Networks (VPNs), tunneling protocols (TLS, IPSec), and secure access service edge (SASE).
- **Selection of effective controls:** Strategies for selecting and deploying appropriate security controls.

3.3 Concepts and strategies to protect data

This topic explores methods for safeguarding data through various strategies, including:

- **Data types and classifications:** Understanding regulated, trade secret, intellectual property, and the classifications of sensitive, confidential, and public data.
- **Data states:** Addressing data at rest, in transit, and in use, along with considerations of data sovereignty and geolocation.
- **Methods to secure data:** Techniques such as geographic restrictions, encryption, hashing, tokenization, obfuscation, and segmentation to protect sensitive information.

3.4 Importance of resilience and recovery in security architecture

This section highlights the need for resilience and recovery mechanisms in maintaining security architecture, discussing:

- **High availability:** Differentiating between load balancing and clustering and site considerations (hot, cold, warm).
- **Capacity planning:** Planning for people, technology, and infrastructure to ensure operational continuity.
- **Testing and backups:** Importance of tabletop exercises, failover processes, backup strategies (onsite/offsite), and encryption for backup data.
- **Recovery techniques:** Methods such as replication, journaling, and the role of power solutions (generators, uninterruptible power supplies) in ensuring operational resilience.

4.0 Security Operations

Security Operations protect an organization's computing resources through various techniques and strategies. Here's a breakdown of the key topics covered:

4.1 Application of common security techniques

This section emphasizes the establishment of secure baselines and hardening targets, including:

- **Secure baselines:** Use these baselines to create, deploy, and maintain standards for system configurations across devices and systems to mitigate vulnerabilities.

- **Hardening targets:** Implementing security measures for various devices, including mobile devices, workstations, cloud infrastructure, servers, and IoT devices, with a focus on minimizing attack surfaces and ensuring secure configurations.

4.2 Security implications of asset management

This area discusses the security implications associated with managing hardware, software, and data assets, including:

- **Acquisition/procurement process:** Ensuring security requirements are embedded in procurement contracts.
- **Assignment/accounting:** Clearly define asset ownership and classify assets based on sensitivity.
- **Monitoring/asset tracking:** Conduct regular inventories and tracking assets to maintain visibility.
- **Disposal/decommissioning:** Implementing secure data sanitization and destruction practices and obtaining certificates of destruction for compliance.

4.3 Vulnerability management activities

This section outlines the various activities related to vulnerability management, including:

- **Identification methods:** Regularly performing vulnerability scans, conducting penetration tests, and utilizing threat feeds to identify weaknesses.
- **Analysis:** Confirming and prioritizing vulnerabilities based on impact assessments and organizational priorities.
- **Response and remediation:** Implementing patching strategies, segmenting networks, and applying compensating controls to address identified vulnerabilities.
- **Validation of remediation:** Conducting rescans and audits to ensure that vulnerabilities have been effectively mitigated and documenting findings.

4.4 Security alerting and monitoring concepts

This area focuses on monitoring computing resources and leveraging tools for effective security operations, covering:

- **Monitoring activities:** Log aggregation, scanning for vulnerabilities, and alerting for suspicious activities.
- **Tools:** Utilizing Security Information and Event Management (SIEM) systems, antivirus software, and other tools for comprehensive security monitoring.

4.5 Enhancing security capabilities

This section discusses the modification of enterprise capabilities to bolster security measures, including:

- **Firewall configurations:** Setting rules and access lists to control network traffic.
- **Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS):** Monitoring for potential intrusions and responding accordingly.
- **Email security measures:** Implementing DMARC, DKIM, and SPF to safeguard against phishing attacks.
- **User behavior analytics:** Analyzing user behavior to detect anomalies and potential threats.

4.6 Identity and access management

This area emphasizes the implementation and maintenance of identity and access management practices, covering:

- **Provisioning and de-provisioning:** Automating user account management processes.
- **Access control models:** Implementing various access controls based on roles and enforcing least privilege principles.
- **Multifactor authentication:** Enhancing security through the use of multiple authentication methods.

4.7 Automation and orchestration

This section highlights the importance of automation and orchestration in security operations, including:

- **Use cases:** Automation of processes such as user provisioning, resource management, and ticketing to improve efficiency.
- **Benefits:** Streamlining security operations, enforcing security baselines, and enhancing response times.

4.8 Incident response activities

This area covers the essential activities associated with incident response, including:

- **Response process:** Following established steps for preparation, detection, analysis, and incident recovery.
- **Training and testing:** Providing ongoing training for incident response teams and conducting simulations to evaluate response plans.

4.9 Data sources for investigations

This section discusses the utilization of various data sources to support investigations, including:

- **Log data analysis:** Collecting and analyzing logs from firewalls, applications, and network devices to identify security incidents.
- **Data sources:** Leveraging vulnerability scans, automated reports, and packet captures for comprehensive analysis during investigations.

5.0 Security Program Management and Oversight

The Security Program Management and Oversight domain focuses on establishing effective governance frameworks, managing risks, ensuring compliance, conducting audits, and promoting security awareness practices. Below is a summary of the key topics covered within this domain:

5.1 Elements of effective security governance

This section discusses the critical components necessary for robust security governance, including:

- **Guidelines and policies:** Key policies such as Acceptable Use Policy (AUP), information security policies, business continuity, disaster recovery, incident response, software development lifecycle (SDLC), and change management.
- **Standards and procedures:** Standards for passwords, access control, physical security, and encryption, alongside procedures for change management and onboarding/offboarding.
- **External considerations:** Compliance with regulatory, legal, and industry standards at local, national, and global levels.
- **Monitoring and revision:** Importance of continuous monitoring and periodic revision of governance structures.
- **Governance structures:** Governance structures include boards, committees, and government entities, as well as the roles and responsibilities of data and system owners, controllers, processors, and custodians.

5.2 Elements of the risk management process

This section elaborates on the risk management process, covering:

- **Risk identification and assessment:** Techniques for identifying and assessing risks, including ad hoc, recurring, and continuous assessments.
- **Risk analysis:** Utilizing qualitative and quantitative methods to analyze risks, including Single Loss Expectancy (SLE), Annualized Loss Expectancy (ALE), and probability assessments.
- **Risk register:** Creation of a risk register that includes key risk indicators, risk owners, and thresholds.
- **Risk management strategies:** Approaches to risk management such as transfer, acceptance, avoidance, and mitigation.
- **Business impact analysis:** Understanding recovery time objectives (RTO), recovery point objectives (RPO), and other metrics related to business continuity.

5.3 Processes associated with third-party risk assessment and management

This area outlines the processes for managing risks associated with third-party vendors, including:

- **Vendor assessment and selection:** Evaluating vendors through penetration testing, audits, and supply chain analysis, along with due diligence and conflict of interest considerations.
- **Agreement types:** Various agreements governing vendor relationships, such as Service-Level Agreements (SLA), Memoranda of Understanding (MOU), and Non-Disclosure Agreements (NDA).
- **Vendor monitoring:** Continuous monitoring of vendor compliance and performance through questionnaires and rules of engagement.

5.4 Elements of effective security compliance

This section discusses the essentials of maintaining compliance with security regulations, including:

- **Compliance reporting:** Internal and external reporting mechanisms for compliance.
- **Consequences of non-compliance:** Potential repercussions include fines, reputational damage, and contractual impacts.
- **Compliance monitoring:** Ongoing due diligence, automation, and attestation processes to ensure compliance with legal and regulatory requirements.
- **Privacy considerations:** Legal implications of data ownership, retention, and the rights of data subjects, including the right to be forgotten.

5.5 Types and purposes of audits and assessments

This area emphasizes the various types of audits and assessments crucial for security management:

- **Attestation and internal audits:** Compliance checks and self-assessments.
- **External audits:** Regulatory examinations and independent third-party audits.
- **Penetration testing:** Penetration testing approaches include physical, offensive, defensive, and integrated testing.

5.6 Implementing security awareness practices

This section focuses on fostering security awareness within organizations through:

- **Phishing awareness:** Recognizing and responding to phishing attempts.
- **Anomalous behavior recognition:** Identifying risky or unexpected behaviors.
- **User guidance and training:** Providing policies, handbooks, and training on insider threats, password management, and operational security.
- **Reporting and monitoring:** Establishing processes for reporting and monitoring security-related activities to enhance awareness and security culture within the organization.

Prepare for performance-based questions with hands-on skills

When you take the CompTIA Security+ exam you'll need to answer skills-based performance-based exam questions (PBQs). Practicing job-related skills is vital for effective exam preparations and passing this exam.

Recommended hardware and software setup

Equipment:

- Tablet, laptop, web server, firewall, router, switch, IDS (Intrusion Detection System), IPS (Intrusion Prevention System), wireless access point, virtual machines, email system, DNS server, IoT devices, smartphone.

Spare hardware:

- NICs (Network Interface Cards), power supplies, managed switch, wireless access point, UPS (Uninterruptible Power Supply).

Tools:

- Wi-Fi Analyzer, Network Mapper, NetFlow Analyzer

Software:

- Windows OS, Linux OS, Kali Linux, Network Emulators, Static and Dynamic Analysis Tools, Code Editor, Sample Code, Pen Testing Software, Vulnerability Scanner, Packet Capture Software, SIEM (Security Information and Event Management), Keyloggers, MDM (Mobile Device Management) Software, VPN (Virtual Private Network), DHCP (Dynamic Host Configuration Protocol) Service, DNS (Domain Name System) Service.

Other resources:

- Access to cloud environments, Sample Network Documentation/Diagrams, and Sample Logs.

Let's summarize the CompTIA recommendations for setting up a practice lab and the key tasks you should practice.

Setting up a practice lab

To effectively set up a practice lab, consider the following recommendations:

- **Create virtual environments:** Use virtual machines to simulate different operating systems and configurations. This allows for safe testing without the risk of impacting production environments.
- **Network configuration:** Set up a small network with routers, switches, and firewalls to practice network segmentation and security measures.
- **Use cloud resources:** Take advantage of cloud environments for scalable testing and deployment of applications.
- **Access to tools:** Ensure access to necessary tools such as vulnerability scanners, packet capture software, and SIEM systems to gain hands-on experience.

Summary of tasks to practice

To enhance your skills and prepare for performance-based questions on the CompTIA Security+ exam, focus on the following key tasks:

- **Network configuration and management:** Configure routers, switches, and firewalls while implementing security controls.
- **Vulnerability scanning:** Use vulnerability scanners to identify and assess security weaknesses within your systems.
- **Incident response simulation:** Practice responding to simulated security incidents, documenting actions taken during the response.
- **Packet analysis:** Capture and analyze packets using tools to detect potential threats and understand network traffic.
- **Security policy development:** Create and evaluate security policies based on best practices and compliance requirements.
- **Cloud security practices:** Implement and manage security measures in cloud environments, focusing on identity and access management.

Review relevant terms and acronyms

While preparing for the CompTIA Security+ certification, it's important to familiarize yourself with key terms and acronyms. For a comprehensive understanding, refer to the **course glossaries** included in the [IBM Cybersecurity Analyst Professional Certificate](#) courses. These glossaries provide definitions and explanations of essential cybersecurity concepts and terminology.

Additionally, you can access the [CompTIA Security+ Exam Objectives](#) PDF for a comprehensive list of acronyms used in exam questions.

Note: To open the PDF, right-click the document link and open the PDF document in a new tab.

Gather your study resources

Collecting the right study resources will enhance your preparation. Here's a list of recommended resources:

- **Lab Setup:** Create a practice lab with the necessary hardware and software, including virtual machines, networking equipment, and security tools.
- **CompTIA resources:** Use official CompTIA materials, including study guides, video training, and practice tests, available on their website.
- **Prior course exams:** Review past exam materials and coursework related to cybersecurity fundamentals to solidify your knowledge.
- **Practice exams:** Take advantage of practice exams available through CompTIA and other platforms. These simulate the exam environment and help you assess your readiness.
- **Online videos:** Explore educational platforms that offer video tutorials and lectures on key Security+ topics.
- **Online communities:** Join online forums and communities to connect with other learners, share resources, and discuss exam strategies.

Create a study schedule

Creating a structured study schedule is vital for effective preparation. Here are some recommendations:

- **Set specific goals:** Break down your study material into manageable sections and set daily or weekly goals.
- **Allocate time blocks:** Dedicate specific time blocks each day for studying different topics, ensuring you cover all domains of the Security+ exam.
- **Incorporate practice exams:** Schedule regular practice exams to assess your progress and identify areas needing more focus.
- **Stay consistent:** Aim to study consistently rather than cramming. Short, focused study sessions are often more effective than long, infrequent ones.

Take practice exams

Regularly taking practice exams is a crucial part of your study strategy. This course includes practice exam resources designed to simulate the actual exam conditions. Additionally, you can access CompTIA's official practice exams, which provide a good benchmark for your preparation.

Summary

This cheat sheet for CompTIA Security+ serves as an important resource for candidates preparing for the certification exam. It outlines the essential exam domains, highlighting key knowledge objectives and recommended study resources. It also emphasizes effective strategies for developing a structured study plan, utilizing various tools for exam preparation, and optimizing learning through testing and review.



Skills Network